CHALLENGE 4:

Nikto est un outil qui fait :

→ Une **détection de fichiers/dossiers dangereux**

→ Une **analyse de bannières (Apache, PHP)**

→ Une **détection de fichiers backup exposés** comme .bak, .old, .swp

1. Créer une page web vulnérable

Nous allons créer un une page dans le web un y insérant le flag a découvrir

```
zo@zo:~$ sudo mkdir /var/www/html/admin
sudo nano /var/www/html/admin/backup.bak
[sudo] password for zo:
zo@zo:~$
```

```
 GNU nano 6.2                                                    /var/www/html/admin/backup.bak
FLAG{nikto_a_decouvert_le_flag_de_jonathan}
```

2. DETECTION DES PAGES AVEC NIKTO

nous allons lancer un scan avec nikto. Nikto va tester plein de chemins, et il va trouver :

```
┌──(kennycs3㉿192)-[~]
└─$ nikto -h http://192.168.112.138

- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          192.168.112.138
+ Target Hostname:    192.168.112.138
+ Target Port:        80
+ Start Time:         2025-04-05 01:03:25 (GMT0)
---------------------------------------------------------------------------
+ Server: Apache/2.4.52 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /: Server may leak inodes via ETags, header found with file /, inode: 29af, size: 631fa389b1bed, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ Apache/2.4.52 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ OPTIONS: Allowed HTTP Methods: POST, OPTIONS, HEAD, GET .
+ /admin/: Directory indexing found.
+ /admin/: This might be interesting.
+ /login.php: Admin login page/section found.
+ /login.php?-s: PHP allows retrieval of the source code via the -s parameter, and may allow command execution. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2012-1823
+ 8909 requests: 0 error(s) and 9 item(s) reported on remote host
+ End Time:           2025-04-05 01:03:39 (GMT0) (14 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

NIKTO ici a détecter la page admin nous allons visiter la page

```
┌──(kennycs3㉿192)-[~]
└─$ curl http://192.168.112.138/admin/

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 3.2 Final//EN">
<html>
 <head>
  <title>Index of /admin</title>
 </head>
 <body>
<h1>Index of /admin</h1>
  <table>
   <tr><th valign="top"><img src="/icons/blank.gif" alt="[ICO]"></th><th><a href="?C=N;O=D">Name</a></th><th><a href="?C=M;O=A">Last modified</a></th><th><a href="?C=S;O=A">Size</a></th><th><a href="?C=D;O=A">Description</a></th></tr>
   <tr><th colspan="5"><hr></th></tr>
<tr><td valign="top"><img src="/icons/back.gif" alt="[PARENTDIR]"></td><td><a href="/">Parent Directory</a></td><td> </td><td align="right">  - </td><td> </td></tr>
<tr><td valign="top"><img src="/icons/unknown.gif" alt="[   ]"></td><td><a href="backup.bak">backup.bak</a></td><td align="right">2025-04-05 00:54  </td><td align="right"> 44 </td><td> </td></tr>
   <tr><th colspan="5"><hr></th></tr>
</table>
<address>Apache/2.4.52 (Ubuntu) Server at 192.168.112.138 Port 80</address>
</body></html>

┌──(kennycs3㉿192)-[~]
└─$ curl http://192.168.112.138/admin/backup.bak

FLAG{nikto_a_decouvert_le_flag_de_jonathan}
```

Apres être entrer sur la page Jai découvert un lien dans la page cache et en me dirigeant dessus Jai découvert le flag